

I. THE VAULT: SECURING THE HEART OF INFORMATION

1.1 The Ultimate Target

If the network is the road and the OS is the house, the **Database** is the safe inside the house. Databases contain the most sensitive information: user passwords, credit card numbers, and personal identity data. At Duy Tan University, we teach that database security is the "last line of defense"—if everything else fails, the data itself must still be protected.

1.2 What is Database Security?

It involves a collective set of processes, tools, and configurations that establish and maintain database confidentiality, integrity, and availability.

- **Structured Data:** SQL databases like MySQL, PostgreSQL, and SQL Server.
- **Unstructured Data:** NoSQL databases like MongoDB.

1.3 Key Threat Vectors

- **Unauthorized Access:** Exploiting weak passwords or misconfigured permissions.
- **Data Leakage:** Accidental exposure of sensitive records through public-facing APIs.
- **SQL Injection:** A critical vulnerability where attackers "trick" the database into running malicious commands.

II. CAREERS IN DATA GOVERNANCE & MANAGEMENT

2.1 The Architect of Information Security In the age of Big Data, the role of a Database Security specialist is more critical than ever. Organizations must comply with strict data residency laws and protection standards.

2.2 Professional Roles

- **Database Administrator (DBA) - Security Focus:** Responsible for patching, hardening, and managing user roles within the database engine.
- **Data Privacy Officer (DPO):** Ensures that the data lifecycle (collection to deletion) follows legal frameworks like the Law on Cybersecurity in Vietnam.
- **Data Analyst (Security):** Monitors database logs to detect unusual patterns, such as a user downloading the entire customer list at midnight.

2.3 Industry Significance With the rapid growth of E-commerce and Fintech in Vietnam, DTU graduates specializing in secure data management are essential for protecting the digital economy.

III. ACCESS CONTROL & ENCRYPTION STRATEGIES

3.1 The Principle of Least Privilege (PoLP)

One of the most important concepts taught at DTU is that a web application should never connect to a database using the "Root" or "Admin" account. Each service should have its own account with the **minimum** permissions required to perform its task (e.g., "Read-Only" for a reporting tool).

3.2 Data Masking and Redaction

- **Data Masking:** Hiding sensitive parts of the data (e.g., showing ****-****-1234 instead of a full credit card number) so that developers or support staff can work with the data without seeing private details.

- **Redaction:** Permanently removing sensitive information from a dataset before it is used for testing.

3.3 Encryption at Rest and in Transit

- **Transparent Data Encryption (TDE):** Encrypting the actual files stored on the hard drive.
- **TLS/SSL:** Ensuring that the connection between the application and the database is encrypted so hackers cannot "sniff" the data as it travels.

IV. DEEP DIVE: PREVENTING SQL INJECTION & AUDITING

4.1 The SQL Injection (SQLi) Vulnerability

SQLi is one of the oldest and most dangerous web attacks. At DTU, students learn how an attacker can bypass a login screen by typing ' OR '1'=1 into a username field.

4.2 The Defense: Prepared Statements

Students are taught to write secure code using **Parameterized Queries** (Prepared Statements). This ensures that the database treats user input as "text" only, never as a "command," effectively neutralizing the attack.

4.3 Database Auditing and Logging

"Trust but verify." Students learn how to configure audit logs to record:

1. **Who** logged in?
2. **What** command did they run?
3. **When** did they access sensitive tables?

4.4 Practical Lab Exercise

1. **Environment:** A test web application connected to a **MySQL** database.
2. **Task 1: The Attack.** Students perform a manual SQL injection to bypass a login page and dump the "Users" table.
3. **Task 2: The Fix.** Students rewrite the PHP or Python backend code to use Prepared Statements, then attempt the attack again to prove it no longer works.
4. **Task 3: Permission Hardening.** Revoking "Drop Table" and "Delete" permissions from the web user account.